

AI & ML Governance + Evaluation Command Centre

PROTOTYPE

A scalable governance model for AI risk — risk appetite, KRIs, and accountable decisions at every stage.

Product brief | Mahesh Kumar | June 2026

THE PROBLEM

AI risk programs are usually strong on policy and weak on coverage. A risk appetite statement and a set of principles exist, but there's no consistent way to see, across every AI system in flight, where it sits against that appetite, who owns it, and what's overdue for re-review. Risk gets documented in one place and decided in another.

THE OPPORTUNITY

Give AI risk the same operating discipline as other risk categories: a registry with consistent risk-banding, named ownership, and a defined escalation path the moment a system crosses a threshold. One model that scales from a handful of pilots today to hundreds of AI systems across business lines — without adding headcount per system.

SCOPE

In scope: a registry of AI systems with risk-based assessments across six domains, each broken into individually-scored controls; a model/agent evaluation layer for ongoing performance and behavior checks; a governance layer that converts risk band into accountable action, owner, and SLA. Out of scope (for now): live model hosting and automated remediation — these sit on the roadmap below.

HOW IT WORKS — FROM RISK APPETITE TO ACCOUNTABLE DECISION

1. Register

Log the AI system: type, business line, data sensitivity, customer impact, owner.

2. Assess

Risk-based questionnaire, scored control by control across impact, model, privacy, data, security & operations — produces a risk band against appetite.

3. Evaluate

Ongoing checks on model and agent behavior — accuracy, bias, guardrail adherence — compared version-over-version.

4. Decide

Risk band or eval result maps to a defined action: accept, escalate, or block — with a named owner, approver, and review date.

BUILT TO GO DEEP — NOT JUST A SCORE

LEVEL 1 — SCORE & BAND

A 0–100 score and risk band per AI system, rolled up from every control across six domains — the headline view for a portfolio scan.

LEVEL 2 — CONTROL STATUS

Every control individually scored Met / Partial / Not Met, tagged by severity (Critical → Low) and traced to a specific clause (e.g., OSFI E-23, Principle 5). One Critical gap caps the whole band — it can't be averaged away by passing controls.

LEVEL 3 — EVIDENCE & TREND

Every Not Met or Partial control carries a remediation owner and target date, rolled into a portfolio-wide findings log. Each system also has a score history, so a reviewer can see the trend, not just the current state.

Example: a product's controls average to a passing score, but one Critical control (independent model validation) is Not Met — the system is still capped at High Risk, with the specific gap, citation, owner, and due date visible on the Findings log.

ROADMAP

NOW — FOUNDATION

Risk-based registry, 6 domains, control-level scoring per question
Severity & citation per control;
severity-weighted risk rollup
Findings log + remediation owner and target date per gap
Score history per system & overdue recertification queue

NEXT — STRENGTHEN

Persistent system of record — durable storage, not session-only
Role-based access (risk owner, approver, governance lead)
Calibration against enterprise risk appetite and KRI thresholds
Product KPIs: adoption, time-to-remediate, decisions followed
Exportable reports for risk committees and audit

LATER — SCALE

Coverage across all business lines, not just pilot systems
Tiered governance by risk level — lighter touch for low-risk systems
Integration with existing model risk (e.g., E-23) inventory and processes
Self-service onboarding for new AI systems as they're built

Live demo: ai-ml-governance-app.streamlit.app | Portfolio: github.com/mkumar84

Working prototype built to explore this problem space. Evaluation runs and scoring rubrics are illustrative; not a substitute for formal regulatory advice.